

NetDrift-Auditor Report: BANK-HQ-FW01

Vendor sonicwall | Audit c45820fe5dea | 2026-10-07 09:28 UTC

Score 39.5/100 (grade F) - 10 rules, 7 nodes, 13 edges

Severity	Count
CRITICAL	3
HIGH	4
MEDIUM	2
LOW	1
INFO	0

Compliance (indicative)

PCI-DSS v4.0 1.2.5: FAIL - Only necessary, approved services/protocols/ports are allowed

PCI-DSS v4.0 1.2.7: FAIL - Network security control rule sets are reviewed regularly (no stale/shadowed/drifted rules)

PCI-DSS v4.0 1.3.1: FAIL - Inbound traffic to the CDE is restricted to what is necessary

ISO 27001:2022 A.8.22: FAIL - Segregation of networks (no unmonitored lateral paths to critical segments)

Findings

[CRITICAL] ND-0001 Lateral movement: LAN 10.10.10.0/24 can reach PCI_Zone_DB in 1 hop(s)

Shortest path: LAN 10.10.10.0/24 -> PCI_Zone_DB. 6 distinct path(s) found. Per-hop services: LAN 10.10.10.0/24->PCI_Zone_DB [tcp/1433]

Remediation: Break the path at its first firewall-enforced hop: tighten or remove rule(s) R7, then re-run the audit to confirm all paths to the asset are closed.

[CRITICAL] ND-0002 Rule R8 exposes RDP/3389 from WAN to DMZ

Rule R8 allows any (WAN, trust 0) to reach App-Srv (DMZ) on administrative/lateral-movement protocol(s): RDP/3389.

Remediation: Remove RDP/3389 from rule R8; require a jump host / bastion in the management zone, MFA, and source-restrict to named admin addresses (/32).

[CRITICAL] ND-0003 Rule R9 is Any-to-Any-to-Any (DMZ->MGMT)

Rule R9: allow DMZ->MGMT, src any, dst any, service any. Violates least privilege. Comment: TEMP-OUTAGE-INC4471 do not remove

Remediation: Delete rule R9. If it is a temporary outage workaround, replace it with the minimum explicit source/destination/port tuple and attach an expiry ticket.

[HIGH] ND-0004 Lateral movement: LAN 10.10.10.0/24 can reach Core_Banking_Switch_Mgmt in 2 hop(s)

Shortest path: LAN 10.10.10.0/24 -> DMZ 10.10.20.0/24 -> Core_Banking_Switch_Mgmt. 4 distinct path(s) found. Per-hop services: LAN 10.10.10.0/24->DMZ 10.10.20.0/24 [any]; DMZ 10.10.20.0/24->Core_Banking_Switch_Mgmt [any]

Remediation: Break the path at its first firewall-enforced hop: tighten or remove rule(s) R1, R5, then re-run the audit to confirm all paths to the asset are closed.

[HIGH] ND-0005 Lateral movement: Internet (WAN) can reach PCI_Zone_DB in 2 hop(s)

Shortest path: Internet (WAN) -> DMZ 10.10.20.0/24 -> PCI_Zone_DB. 2 distinct path(s) found. Per-hop services: Internet (WAN)->DMZ 10.10.20.0/24 [tcp/80, tcp/443, tcp/3389]; DMZ 10.10.20.0/24->PCI_Zone_DB [tcp/1433]

Remediation: Break the path at its first firewall-enforced hop: tighten or remove rule(s) R3, R8, then re-run the audit to confirm all paths to the asset are closed.

[HIGH] ND-0006 Lateral movement: Internet (WAN) can reach Core_Banking_Switch_Mgmt in 2 hop(s)

Shortest path: Internet (WAN) -> DMZ 10.10.20.0/24 -> Core_Banking_Switch_Mgmt. 2 distinct path(s) found.
Per-hop services: Internet (WAN)->DMZ 10.10.20.0/24 [tcp/80, tcp/443, tcp/3389]; DMZ 10.10.20.0/24->Core_Banking_Switch_Mgmt [any]

Remediation: Break the path at its first firewall-enforced hop: tighten or remove rule(s) R3, R8, then re-run the audit to confirm all paths to the asset are closed.

[HIGH] ND-0007 Rule R6 is shadowed by R5 (deny rule never takes effect)

Rule R6 (deny, LAN->DMZ, Users-Net -> App-Srv, SSH) is fully matched by earlier rule R5 (allow, Users-Net -> DMZ-Net, any); it can never be evaluated.

Remediation: Delete rule R6, or move it above rule R5 if the intent was a more specific exception.

[MEDIUM] ND-0008 Inbound NAT publishes 'Web-Srv' from WAN (WAN-VIP-Web -> Web-Srv, service HTTPS)

An inbound destination NAT maps an externally reachable address to an internal host. Verify the matching access rule is minimal.

Remediation: Confirm business need, restrict the service, and place the host in a DMZ.

[MEDIUM] ND-0009 Rule R5 permits ANY service LAN->DMZ (Users-Net -> DMZ-Net)

Rule R5: allow LAN->DMZ, src Users-Net, dst DMZ-Net, service any. Violates least privilege. Comment: Legacy users to DMZ

Remediation: Replace service 'any' in rule R5 with the explicit ports required, and restrict the destination to specific hosts (/32) or at most a /28.

[LOW] ND-0010 Rule R3 exposes HTTP (cleartext; verify it is not a management UI)/80 from WAN to DMZ

Rule R3 allows any (WAN, trust 0) to reach Web-Srv (DMZ) on administrative/lateral-movement protocol(s): HTTP (cleartext; verify it is not a management UI)/80.

Remediation: Remove HTTP (cleartext; verify it is not a management UI)/80 from rule R3; require a jump host / bastion in the management zone, MFA, and source-restrict to named admin addresses (/32).

Lateral movement paths (top 15)

[CRITICAL] LAN 10.10.10.0/24 -> PCI_Zone_DB (1 hop(s); rules R7)

[HIGH] Internet (WAN) -> DMZ 10.10.20.0/24 -> Core_Banking_Switch_Mgmt (2 hop(s); rules R3, R8, R9)

[HIGH] LAN 10.10.10.0/24 -> DMZ 10.10.20.0/24 -> Core_Banking_Switch_Mgmt (2 hop(s); rules R1, R5, R9)

[HIGH] Internet (WAN) -> DMZ 10.10.20.0/24 -> PCI_Zone_DB (2 hop(s); rules R3, R8, R2)

[HIGH] LAN 10.10.10.0/24 -> PCI_DB 10.10.30.0/24 -> PCI_Zone_DB (2 hop(s); rules R7)

[HIGH] LAN 10.10.10.0/24 -> DMZ 10.10.20.0/24 -> PCI_Zone_DB (2 hop(s); rules R1, R5, R2)

[HIGH] Internet (WAN) -> DMZ 10.10.20.0/24 -> MGMT 10.10.99.0/24 -> Core_Banking_Switch_Mgmt (3 hop(s); rules R3, R8, R9)

[HIGH] LAN 10.10.10.0/24 -> Internet (WAN) -> DMZ 10.10.20.0/24 -> Core_Banking_Switch_Mgmt (3 hop(s); rules R4, R3, R8, R9)

[HIGH] LAN 10.10.10.0/24 -> DMZ 10.10.20.0/24 -> MGMT 10.10.99.0/24 -> Core_Banking_Switch_Mgmt (3 hop(s); rules R1, R5, R9)

[HIGH] Internet (WAN) -> DMZ 10.10.20.0/24 -> PCI_DB 10.10.30.0/24 -> PCI_Zone_DB (3 hop(s); rules R3, R8, R2)

[HIGH] LAN 10.10.10.0/24 -> Internet (WAN) -> DMZ 10.10.20.0/24 -> PCI_Zone_DB (3 hop(s); rules R4, R3, R8, R2)

[HIGH] LAN 10.10.10.0/24 -> DMZ 10.10.20.0/24 -> PCI_DB 10.10.30.0/24 -> PCI_Zone_DB (3 hop(s); rules R1, R5, R2)

[MEDIUM] LAN 10.10.10.0/24 -> Internet (WAN) -> DMZ 10.10.20.0/24 -> MGMT 10.10.99.0/24 -> Core_Banking_Switch_Mgmt (4 hop(s); rules R4, R3, R8, R9)

[MEDIUM] LAN 10.10.10.0/24 -> Internet (WAN) -> DMZ 10.10.20.0/24 -> PCI_DB 10.10.30.0/24 -> PCI_Zone_DB (4 hop(s); rules R4, R3, R8, R2)